

# Bonistock Product Review & Improvement Roadmap

---

**Executive Summary:** Bonistock is a solid, production-grade Next.js app with good security practices and a smart Day Pass monetization model. However, the product currently sells "vitamins" (nice-to-have features) rather than "painkillers" (must-have solutions). This document outlines critical improvements needed to drive conversions, retention, and revenue.

## Current State Assessment

---

### What's Working Well

1. **Day Pass Model** — Low-friction, impulse-buy pricing that reduces commitment anxiety
2. **Broker Comparison + CPA Revenue** — Smart diversification beyond subscriptions
3. **Germany Market Focus** — Under-served market with Sparplan culture
4. **Mobile-First Architecture** — Capacitor wrapper aligns with target demographic
5. **Security Foundation** — Proper auth, encryption, audit logging, soft deletes

### Critical Issues Found in Code Review

#### CRITICAL: In-Memory Rate Limiting

- `src/lib/rate-limit.ts` uses a `Map` stored in memory
- Won't work in serverless (Vercel) or multi-instance deployments
- Each instance has its own counter — rate limits are effectively bypassed
- **Fix:** Implement Redis or Upstash for distributed rate limiting

#### CRITICAL: In-Memory FMP Rate Limit

- `src/lib/fmp.ts` tracks API calls in memory (`requestCount`)
- Resets on every cold start, will exceed 250/day limit in production

- **Fix:** Add Redis-backed counter or queue-based sync

### HIGH: allowDangerousEmailAccountLinking: true

- All OAuth providers have this enabled
- If someone compromises a Facebook account, they can take over the Bonistock account
- **Fix:** Disable or add additional verification for account linking

### MEDIUM: No CSRF on State-Changing GETs

- `/api/auth/verify-email?token=...` and `/api/auth/verify-email-change?token=...` mutate state via GET
- **Fix:** Convert to POST with proper CSRF protection

### MEDIUM: Apple OAuth Missing Env Validation

- `APPLE_OAUTH_CLIENT_ID` and `APPLE_OAUTH_CLIENT_SECRET` not in `env.ts` schema
- App will crash at runtime if missing

### LOW: trustHost: true in NextAuth

- Disables host validation — potential issue with certain proxies

### LOW: Logger Leaks in Dev

- `logger.ts` logs full objects including potentially sensitive data
- `formatArgs` function doesn't redact anything

## Product Strategy: From Vitamins to Painkillers

---

### The Core Problem

Your free tier is too generous:

- Top 5 stocks weekly
- 1 auto-mix per month
- Full broker comparison

Users get **80% of value for free**. The paywall hits too late — after they've already satisfied their curiosity.

### Competitive Landscape Reality

| Feature                     | Bonistock           | TipRanks (\$30) | Seeking Alpha (\$20) | Simply Wall St (\$10) |
|-----------------------------|---------------------|-----------------|----------------------|-----------------------|
| Upside scoring              | Yes                 | Yes             | Partial              | Yes                   |
| Auto-mix                    | <b>Yes</b>          | No              | No                   | No                    |
| Broker comparison (neutral) | <b>Yes</b>          | No              | No                   | No                    |
| Built for beginners         | <b>Yes</b>          | Partial         | No                   | Yes                   |
| Free tier value             | <b>Too generous</b> | Limited         | Hard paywall         | Limited               |
| Pay-per-use                 | <b>Yes</b>          | No              | No                   | No                    |

*The issue: Your differentiation (auto-mix, plain English) is nice-to-have, not must-have. Nobody wakes up at 3am thinking "I need an auto-mix engine." They wake up thinking "am I losing money?"*

## Priority Improvements

### Phase 1: Fix Conversion (Weeks 1-4)

#### 1. Tighten Free Tier

**Current:** Top 5 stocks, 1 auto-mix/month, full broker comparison

**New:** Top 3 stocks only, no auto-mix, comparison table only (no deep-links)

**Rationale:** Make free users feel limitations immediately. Right now they don't experience enough pain to upgrade.

#### 2. Add Paper Portfolio (Free)

- Let users simulate one mix, track for 30 days
- Weekly "your paper portfolio is up 5%" emails
- **This is the hook** — users see value before spending money

#### 3. Add Social Proof

- "Most mixed stocks this week" (anonymized aggregate)
- "47 users added AAPL to their mix today"
- Creates FOMO and demonstrates active usage

#### 4. Fix Rate Limiting

- Replace in-memory with Redis/Upstash
- Critical for production stability

### Phase 2: Retention (Months 1-2)

#### 5. Portfolio Tracking

**The biggest missing feature.** Users build a mix, buy at their broker, and never return.

**Build:**

- Manual portfolio entry (sync with broker APIs later)
- Performance vs S&P 500 benchmark
- Rebalancing alerts: "Your AAPL is now 40% of portfolio — consider trimming"
- Dividend tracking: "You earned \$12.40 this month"

**This is your retention hook.** Without it, churn will be brutal.

#### 6. Better Alerts

**Current:** "Price target alerts" — boring, every app has this

**New alert types:**

- "Analyst downgraded AAPL — your conviction score dropped from 8.2 to 5.1"
- "3 stocks in your watchlist hit 'strong buy' this week"
- "Your auto-mix from March is beating S&P by 12%"
- "NVDA just entered top 5 upside list (wasn't there last week)"

#### 7. Weekly Newsletter (Free to All)

- "The 3 stocks analysts are most wrong about" — contrarian, spicy
- Track how well analyst predictions actually perform
- Build trust through transparency

- Lead generation for free users

## Phase 3: Differentiation (Months 2-4)

### 8. Germany Tax Features

German investors obsess over:

- **Steuer-Optimierung** (tax optimization)
- **Sparplan costs**
- **Freibetrag tracking**

**Build:**

- Freibetrag calculator: "If you sell these gains, you'll owe €X tax. Consider waiting until January?"
- Sparplan comparison: "This ETF costs €0 on Trade Republic vs €1.50 on Scalable"
- Steuerbescheinigung export (huge pain point)

### 9. "Sleep Well" Risk Score

**Current:** All upside, no downside. Beginners are scared of losing money.

**New:**

- "Worst case scenario: If analysts are wrong, you'd lose 15%"
- Stop-loss suggestions based on volatility
- "Sleep well" score combining diversification, volatility, analyst disagreement

### 10. Public Mix Sharing + Leaderboards

- Share mixes with performance tracking
- Leaderboard of top-performing user mixes (with disclaimers)
- Reddit-style "conviction score" from user behavior

## Phase 4: Scale (Months 6+)

### 11. Broker API Integrations

- Actual execution, not just deep-links
- Small commission per trade
- **This is where real money is**

## 12. B2B White-Label

- License scoring to neobrokers
- They need activation tools for dormant accounts
- **Pivot narrative:** "We convert account openers into active traders"

## 13. Additional Markets

- UK, France, Netherlands
- Region-specific tax features

# Pricing Psychology Fixes

## Current Pricing Issues

| Issue                                | Problem                                    |
|--------------------------------------|--------------------------------------------|
| Free → Day Pass \$2.99 → Plus \$6.99 | Too cheap — signals "not serious"          |
| 1-Day / 3-Day / 12-Day Pass          | Confusing — users don't know which to pick |

## Recommended Changes

### Plus Subscription:

- Raise to \$9.99/mo or \$79/yr
- Still under competitors, but feels premium
- Add "Student" tier at \$4.99/mo with verification

### Day Passes:

- Simplify to: "Weekend Pass" (\$4.99, Fri-Sun) and "Full Access Pass" (\$14.99, 14 days)
- Clear use cases reduce decision paralysis

# Content Marketing Engine

---

## Current: Passive SEO on Ticker Pages

**Problem:** Too passive, takes months to rank

## Active Content Strategy

### 1. Weekly "Upside Report" Newsletter

- Free to all (not just Plus)
- Contrarian takes: "The 3 stocks analysts are most wrong about"
- Track analyst prediction accuracy over time
- Build trust through transparency

### 2. "Analysts vs Reality" Series

- Quarterly report: How well did Q1 analyst predictions perform?
- Name and shame (or praise) consistently wrong/right analysts
- Data-driven, shareable content

### 3. TikTok/Reels Content

- "I gave Bonistock \$500, here's what happened"
- Real user journeys, not product demos
- 30-second "this week's most controversial pick"

### 4. Reddit/Discord Strategy

- Weekly "Top 5 Upside" posts in r/stocks, r/investing, r/ETFs
- German communities: r/Finanzen, r/mauerstrassenwetten
- Provide genuine value first, link second

## Strategic Narrative Pivot

---

### Current Pitch

*"We help beginners pick stocks with analyst consensus data"*

## Problem

Brokers already have research tools. This makes you a nice-to-have feature, not an acquisition target.

## New Pitch

*"We convert account openers into active traders"*

## Metric to Track

"Users who use Bonistock make 3x more trades in their first 90 days"

## Why This Matters

Brokers spend \$50-150 CPA to acquire funded accounts but struggle with activation. If you can prove you activate dormant users, you become an acquisition target.

## Technical Debt to Address

---

### Immediate (This Sprint)

1. Replace in-memory rate limiting with Redis
2. Add Apple OAuth env vars to validation schema
3. Fix CSRF on state-changing GET endpoints

### Short-Term (Next Month)

4. Remove or secure `allowDangerousEmailAccountLinking`
5. Add sensitive data redaction to logger
6. Implement distributed FMP rate limit counter

### Medium-Term (Next Quarter)



- 7. Add comprehensive API testing for auth flows
- 8. Implement proper error boundaries
- 9. Add performance monitoring for database queries

## Success Metrics to Track

---

### Conversion

| Metric                               | Target |
|--------------------------------------|--------|
| Free → Day Pass conversion           | 8-12%  |
| Day Pass → Plus conversion (60 days) | 25-35% |
| Free → Plus direct conversion        | 3-5%   |

### Retention

| Metric                                   | Target       |
|------------------------------------------|--------------|
| Day 7 retention                          | 40%          |
| Day 30 retention                         | 25%          |
| Portfolio tracking users vs non-tracking | 2x retention |

### Revenue

| Metric                         | Target        |
|--------------------------------|---------------|
| Blended ARPU                   | \$2-3/mo      |
| Day Pass revenue as % of total | 20-30%        |
| Broker CPA revenue             | \$1-2/user/mo |

### Engagement

| Metric                   | Target  |
|--------------------------|---------|
| Alert open rates         | 60%+    |
| Newsletter click-through | 15%+    |
| Mix shares per week      | Growing |

## Conclusion

Bonistock has a solid technical foundation and smart monetization mechanics. The critical gap is **product-market fit execution** — making users feel enough pain in the free tier to convert, then giving them retention hooks that keep them engaged long-term.

### The Three Bets

1. **Tighter free tier** drives conversion
2. **Portfolio tracking** drives retention
3. **"Activate traders" narrative** drives acquisition value

Build these three, and you have a real business. Without them, you're a nice tool that users try once and forget.